Estratégia Concursos

Aula 34

DataPrev (Analista de TI - Desenvolvimento de Software) Passo Estratégico de Conhecimentos Específicos - 2024 (Pós-Edital)

Autor:

09 de Setembro de 2024

11225354498 - Maria Vitória Gonçalves Vieira

ISO 27001:2022

Sumário

Conteúdo 2
Glossário de termos 3
Roteiro de revisão 17
Conceitos Básicos 17
Princípios Fundamentais 18
Requisitos do SGSI - Contexto da Organização 19
Requisitos do SGSI - Liderança 20
Requisitos do SGSI - Planejamento 22
Requisitos do SGSI - Apoio 25
Requisitos do SGSI - Operação 28
Requisitos do SGSI - Avaliação de Desempenho 29
Requisitos do SGSI - Melhoria 32
Controles (Anexo A) 33
Aposta estratégica 45
Questões Estratégicas 46
Questionário de revisão e aperfeiçoamento 50
Perguntas 50
Perguntas e Respostas 51
Lista de Questões Estratégicas 53

Conteúdo

ISO 27001. Conceitos Básicos. Princípios Fundamentais. Termos e Definições. Requisitos do SGSI. Contexto da organização. Liderança. Planejamento. Apoio. Operação. Avaliação de Desempenho. Melhoria. Objetivos de controle.

Análise Estatística

Inicialmente, convém destacar o percentual de incidência do assunto, dentro da disciplina Segurança da Informação em concursos/cargos similares. Quanto maior o percentual de cobrança de um dado assunto, maior sua importância.

11225354498 - Maria Vitória Gonçalves Vieira

Obs.: *um mesmo assunto pode ser classificado em mais de um tópico devido à multidisciplinaridade de conteúdo.*

Assunto	Relevância na disciplina em concursos similares
Criptografia	**11.4 %**
Análise de Vulnerabilidade e Gestão de Riscos	**11.4 %**
Plano de Continuidade de Negócios	**8.6 %**
Norma 27005	**8.6 %**
Backup em Segurança da Informação	**5.7 %**
Conceitos Básicos em Segurança da Informação	**5.7 %**
Políticas de Segurança de Informação	**5.7 %**
Norma ISO 27001/27002	**5.7 %**
Certificação Digital em Segurança da Informação	**5.7 %**
Ataques e ameaças	**5.7 %**
Planos de contingência	**2.9 %**
Sistemas de Prevenção-Detecção de Intrusão	**2.9 %**
1. IDS (Intrusion Detection System)	**2.9 %**
2. IPS (Intrusion Prevention System)	**2.9 %**
Segurança de sistemas de informação	**2.9 %**
Infraestrutura de Chaves Publicas (PKI)	**2.9 %**
Controles de segurança	**2.9 %**
Assinatura Digital	**2.9 %**
Malware	**2.9 %**

GLOSSÁRIO DE TERMOS

Faremos uma lista de termos que são relevantes ao entendimento do assunto desta aula. Caso tenha alguma dúvida durante a leitura, esta seção pode lhe ajudar a esclarecer.

Vamos listar os termos do glossário de acordo como eles aparecem na norma 27000 (a base da "família de normas")

3.1 controle de acesso

meios para garantir que o acesso a ativos seja autorizado e restrito com base nos requisitos comerciais e de segurança

3.2 ataque

tentativa de destruir, expor, alterar, desabilitar, roubar ou obter acesso não autorizado ou uso não autorizado de um ativo

3.3 auditoria

processo sistemático, independente e documentado para obter evidências de auditoria e avaliá-las de forma objetiva para determinar a extensão em que os critérios de auditoria são cumpridos definidos na ISO 19011.

3.4 escopo da auditoria

extensão e limites de uma auditoria

3.5 autenticação

provisão de garantia de que uma característica reivindicada de uma entidade está correta

3.6 autenticidade

propriedade de que uma entidade é o que ela afirma ser

11225354498 - Maria Vitória Gonçalves Vieira

3.7 disponibilidade

propriedade de ser acessível e utilizável sob demanda por uma entidade autorizada

3.8 medida de base

medida definida em termos de um atributo e o método para quantificá-lo

3.9 competência

habilidade de aplicar conhecimentos e habilidades para alcançar resultados pretendidos

3.10 confidencialidade

propriedade de que a informação não é disponibilizada ou divulgada a indivíduos, entidades ou processos não autorizados

3.11 conformidade

cumprimento de um requisito

3.12 consequência

resultado de um evento afetando objetivos

3.13 melhoria contínua

atividade recorrente para aprimorar o desempenho

11225354498 - Maria Vitória Gonçalves Vieira

3.14 controle

medida que modifica o risco

3.15 objetivo de controle

afirmação que descreve o que deve ser alcançado como resultado da implementação dos controles

3.16 correção

ação para eliminar uma não conformidade detectada

3.17 ação corretiva

ação para eliminar a causa de uma não conformidade e prevenir a recorrência

3.18 medida derivada

medida que é definida como função de dois ou mais valores de medidas de base

3.19 informação documentada

informação que deve ser controlada e mantida por uma organização e o meio no qual ela está contida

3.20 eficácia

extensão em que as atividades planejadas são realizadas e os resultados planejados são alcançados

11225354498 - Maria Vitória Gonçalves Vieira

3.21 evento

ocorrência ou mudança de um conjunto específico de circunstâncias

3.22 contexto externo

ambiente externo no qual a organização busca alcançar seus objetivos

3.23 governança da segurança da informação

sistema pelo qual as atividades de segurança da informação de uma organização são dirigidas e controladas

3.24 órgão de governança

pessoa ou grupo de pessoas responsáveis pelo desempenho e conformidade da organização

3.25 indicador

medida que fornece uma estimativa ou avaliação

3.26 necessidade de informação

insight necessário para gerenciar objetivos, metas, riscos e problemas

3.27 instalações de processamento de informações

11225354498 - Maria Vitória Gonçalves Vieira

qualquer sistema de processamento de informações, serviço ou infraestrutura, ou o local físico onde está localizado

3.28 segurança da informação

preservação da confidencialidade, integridade e disponibilidade da informação

3.29 continuidade da segurança da informação

processos e procedimentos para garantir operações contínuas de segurança da informação

3.30 evento de segurança da informação

ocorrência identificada de um estado de sistema, serviço ou rede que indica uma possível violação da política de segurança da informação ou falha nos controles, ou uma situação previamente desconhecida que pode ser relevante para a segurança

3.31 incidente de segurança da informação

um único ou uma série de eventos de segurança da informação indesejados ou inesperados que têm uma probabilidade significativa de comprometer as operações comerciais e ameaçar a segurança da informação

3.32 gerenciamento de incidentes de segurança da informação

conjunto de processos para detectar, relatar, avaliar, responder, lidar com e aprender com incidentes de segurança da informação

3.33 profissional do sistema de gestão de segurança da informação

11225354498 - Maria Vitória Gonçalves Vieira

pessoa que estabelece, implementa, mantém e melhora continuamente um ou mais processos do sistema de gestão de segurança da informação

3.34 comunidade de compartilhamento de informações

grupo de organizações que concordam em compartilhar informações

3.35 sistema de informação

conjunto de aplicativos, serviços, ativos de tecnologia da informação ou outros componentes de manipulação de informações

3.36 integridade

propriedade de precisão e completude

3.37 parte interessada

pessoa ou organização que pode afetar, ser afetada ou perceber-se afetada por uma decisão ou atividade

3.38 contexto interno

ambiente interno no qual a organização busca alcançar seus objetivos

3.39 nível de risco

magnitude de um risco expressa em termos da combinação de consequências e sua probabilidade

11225354498 - Maria Vitória Gonçalves Vieira

3.40 probabilidade

chance de algo acontecer

3.41 sistema de gestão

conjunto de elementos inter-relacionados ou interagindo de uma organização para estabelecer políticas e objetivos e processos para alcançar esses objetivos

3.42 medida

variável à qual um valor é atribuído como resultado de medição

3.43 medição

processo para determinar um valor

3.44 função de medição

algoritmo ou cálculo realizado para combinar duas ou mais medidas de base

3.45 método de medição

sequência lógica de operações, descrita de forma genérica, usada para quantificar um atributo em relação a uma escala especificada

3.46 monitoramento

determinação do estado de um sistema, um processo ou uma atividade

11225354498 - Maria Vitória Gonçalves Vieira

3.47 não conformidade

não cumprimento de um requisito

3.48 não repúdio

habilidade de provar a ocorrência de um evento ou ação reivindicada e suas entidades de origem

3.49 objetivo

resultado a ser alcançado

3.50 organização

pessoa ou grupo de pessoas que possui suas próprias funções com responsabilidades, autoridades e relacionamentos para alcançar seus objetivos

3.51 terceirizar

fazer um acordo em que uma organização externa executa parte da função ou processo de uma organização

3.52 desempenho

resultado mensurável

3.53 política

intenções e direção de uma organização, expressas formalmente por sua alta administração

11225354498 - Maria Vitória Gonçalves Vieira

3.54 processo

conjunto de atividades inter-relacionadas ou interativas que transformam entradas em saídas

3.55 confiabilidade

propriedade de comportamento e resultados consistentes e intencionais

3.56 requisito

necessidade ou expectativa que é declarada, geralmente implícita ou obrigatória

3.57 risco residual

risco restante após o tratamento de risco

3.58 revisão

atividade realizada para determinar a adequação, suficiência e eficácia do assunto em questão para alcançar objetivos estabelecidos

3.59 objeto de revisão

item específico sendo revisado

3.60 objetivo de revisão

declaração descrevendo o que deve ser alcançado como resultado de uma revisão

3.61 risco

efeito da incerteza nos objetivos

3.62 aceitação

decisão de assumir um risco específico

3.63 tratamento de risco

processo para modificar o risco

3.64 requisito de segurança da informação

necessidade ou expectativa que é declarada, geralmente implícita ou obrigatória, relacionada à segurança da informação

3.65 risco inaceitável

risco que excede o nível de risco tolerado pela organização

3.66 risco tolerável

risco dentro do nível de risco tolerado pela organização

3.67 risco aceitável

risco que é aceito explicitamente

11225354498 - Maria Vitória Gonçalves Vieira

3.68 conformidade legal

conformidade com leis, regulamentos, obrigações contratuais, requisitos acordados e regras ou normas relevantes

3.69 ameaça

potencial causa de um incidente de segurança da informação que pode resultar em dano à organização ou suas partes interessadas

3.70 valor

grau em que um conjunto de características de uma entidade satisfaz os requisitos estabelecidos pelo cliente, usuário ou outra entidade

3.71 vulnerabilidade

fraqueza de um ativo ou grupo de ativos que pode ser explorada por uma ou mais ameaças

3.72 tratamento de risco

processo para modificar o risco

3.73 tratamento de risco residual

processo para modificar o risco residual

3.74 avaliação de risco

11225354498 - Maria Vitória Gonçalves Vieira

processo de comparação do nível de risco com critérios de risco para determinar se o nível de risco é tolerável ou se o risco precisa ser tratado

3.75 critério de risco

conjunto de critérios usados para avaliar o risco com base nos resultados da análise de risco e determinar a aceitabilidade do risco

3.76 análise de risco

processo para compreender a natureza do risco e determinar o nível de risco

3.77 plano de tratamento de risco

plano que identifica os controles selecionados e ações corretivas a serem implementados para tratar o risco de acordo com critérios de risco e recursos disponíveis

3.78 ponto de partida

condição que existe antes de um projeto, processo ou atividade iniciar

3.79 ambiente

entorno no qual uma organização opera, incluindo aspectos culturais, sociais, políticos, regulatórios, financeiros, tecnológicos, econômicos, naturais e competitivos

3.80 acordo

consenso entre duas ou mais partes que pode ser verbal, escrito ou implícito

11225354498 - Maria Vitória Gonçalves Vieira

3.81 procedimento

forma especificada de realizar uma atividade ou um processo

3.82 monitoramento de segurança da informação

processo sistemático e repetitivo de avaliar a segurança da informação de uma organização para determinar se os controles são eficazes e estão sendo aplicados corretamente

3.83 exposição ao risco

situação em que um indivíduo, organização, ativo ou grupo de ativos está exposto a uma ameaça específica

3.84 segurança

estado de ser livre de perigo, dano ou risco

3.85 processo de gestão de segurança da informação

conjunto de processos coordenados que estabelecem, implementam, operam, monitoram, analisam criticamente, mantêm e melhoram o sistema de gestão de segurança da informação

3.86 programa de segurança da informação

conjunto de atividades planejadas que visam alcançar os objetivos de segurança da informação

11225354498 - Maria Vitória Gonçalves Vieira

3.87 avaliação

processo sistemático, documentado e independente para obter evidências de auditoria e avaliá-las de forma objetiva para determinar a extensão em que os critérios de avaliação são atendidos

3.88 objetivo de avaliação

afirmação que descreve o que deve ser alcançado como resultado da avaliação

3.89 autorização

aprovação formal para prosseguir com uma atividade ou processo

3.90 risco aceitável

risco que é aceito explicitamente

Roteiro de revisão

A ideia desta seção é apresentar um roteiro para que você realize uma revisão completa do assunto e, ao mesmo tempo, destacar aspectos do conteúdo que merecem atenção.

Conceitos Básicos

A ISO 27001 é uma norma internacional que fornece requisitos para a implementação, operação, monitoramento, revisão, manutenção e melhoria de um Sistema de Gestão de Segurança da Informação (SGSI). Ela se baseia na aplicação de um processo de

gestão de risco e dá garantias aos stakeholders de que a organização está devidamente protegendo seus dados.

A norma teve suas raízes na versão britânica BS 7799, publicada em 1995. A BS 7799 foi revisada e finalmente incorporada ao conjunto de normas ISO 27000 (hoje, uma "família de normas"). A primeira versão da ISO 27001 foi publicada em 2005, e a versão atualmente em vigor foi publicada em 2022.

O escopo da ISO 27001 abrange a implementação e manutenção de um SGSI. Isso inclui a avaliação e o tratamento de riscos de segurança da informação, bem como a implementação de um conjunto adequado de controles de segurança da informação. A norma também cobre questões como liderança e comprometimento da alta direção, definição de papéis e responsabilidades, competência e conscientização, comunicação interna e externa, e gestão de documentos e registros.

Benefícios da ISO 27001

A implementação da ISO 27001 traz vários benefícios para uma organização, incluindo:

- Proteção de informações confidenciais para prevenir sua perda, roubo e corrupção.
- Aumento da resiliência aos ataques cibernéticos.
- Melhoria na reputação da empresa, aumentando a satisfação dos stakeholders.
- Conformidade com requisitos de negócios, legais, contratuais e regulatórios.
- Melhoria da estrutura e foco de uma empresa através da definição de responsabilidades claras para a gestão da informação.
- Redução de incidentes de segurança da informação, economizando tempo e custos.
- Demonstração de credibilidade e confiança, permitindo que uma organização se diferencie da concorrência.



11225354498 - Maria Vitória Gonçalves Vieira

É importante que um sistema de gestão da segurança da informação seja parte e esteja integrado com os processos da organização e com a estrutura de administração global e que a segurança da informação seja considerada no projeto dos processos, sistemas de informação e controles. Logo, é esperado que a implementação de um sistema de gestão de segurança da informação seja planejado de acordo com as necessidades da organização.

Esta norma pode ser usada por partes internas e externas para avaliar a capacidade da organização em atender os seus próprios requisitos de segurança da informação. Ela também inclui requisitos para a avaliação e tratamento de riscos de segurança da informação voltados para as necessidades da organização. Esses requisitos são genéricos e aplicáveis a todas as organizações independentemente do tipo, tamanho ou natureza.

Princípios Fundamentais

As definições a seguir não estão explicitamente na norma, mas são mencionadas em diversas ocasiões, portanto vamos detalhá-las nas próximas seções.

Confidencialidade:

Refere-se à proteção das informações contra o acesso e divulgação não autorizados. A ideia é que apenas as pessoas ou sistemas autorizados possam acessar ou manipular os dados. Violações de confidencialidade podem ocorrer devido a ataques cibernéticos, vazamentos de dados ou falhas humanas.

Integridade:

Garante que as informações sejam precisas e completas, e que elas não sejam alteradas de forma não autorizada. Isso envolve a proteção dos dados contra alteração, exclusão ou corrupção. A integridade também se refere à validade e exatidão das informações ao longo do tempo.

Disponibilidade:

Refere-se à garantia de que as informações estejam acessíveis para usuários autorizados quando necessário. Isso envolve a proteção dos sistemas contra interrupções, sejam elas devido a ataques maliciosos (como ataques DDoS), falhas de sistema, desastres naturais ou falhas humanas.

11225354498 - Maria Vitória Gonçalves Vieira

Autenticidade:

Relaciona-se com a verificação da identidade de um usuário, sistema ou entidade. A autenticidade garante que as partes envolvidas em uma comunicação ou transação sejam de fato quem afirmam ser, o que é fundamental para evitar ações de usurpação de identidade ou acessos não autorizados.

Irretratabilidade (ou Não Repúdio):

Refere-se à garantia de que uma operação ou evento não possa ser negado posteriormente. Em outras palavras, se um usuário realizou uma ação (por exemplo, enviou uma mensagem ou realizou uma transação), não pode negar a autoria da ação posteriormente. Isso é frequentemente assegurado através de mecanismos como registros de log detalhados e assinaturas digitais.

Requisitos do SGSI - Contexto da Organização

Entendendo a organização e seu contexto

A organização deve determinar as questões internas e externas que são relevantes para o seu propósito e que afetam sua capacidade de alcançar os resultados pretendidos do seu sistema de gestão da segurança da informação.

Entendendo as necessidades e as expectativas das partes interessadas

A organização deve determinar:

a) as partes interessadas que são relevantes para o sistema de gestão da segurança da informação;

b) os requisitos relevantes dessas partes interessadas;

c) quais desses requisitos serão endereçados pelo sistema de gestão da segurança da informação.

Determinando o escopo do sistema de gestão da segurança da informação

A organização deve determinar os limites e a aplicabilidade do sistema de gestão da segurança da informação para estabelecer o seu escopo.

11225354498 - Maria Vitória Gonçalves Vieira

Ao determinar este escopo, a organização deve considerar:

a) as questões internas e externas;

b) os requisitos da organização;

c) as interfaces e dependências entre as atividades desempenhadas pela organização e aquelas que são desempenhadas por outras organizações.

O escopo deve estar disponível como informação documentada.

Sistema de gestão da segurança da informação

A organização deve estabelecer, implementar, manter e melhorar continuamente um sistema de gestão da segurança da informação, incluindo os processos necessários e suas interações, de acordo com os requisitos deste documento.

Requisitos do SGSI - Liderança

Liderança e Comprometimento

A Alta Direção deve demonstrar sua liderança e comprometimento em relação ao sistema de gestão da segurança da informação pelos seguintes meios:

a) assegurando que a política de segurança da informação e os objetivos de segurança da informação estejam estabelecidos e sejam compatíveis com a direção estratégica da organização;

b) assegurando a integração dos requisitos do sistema de gestão da segurança da informação nos processos da organização;

c) assegurando que os recursos necessários para o sistema de gestão da segurança da informação estejam disponíveis;

d) comunicando a importância de uma gestão eficaz da segurança da informação e da conformidade com os requisitos do sistema de gestão da segurança da informação;

e) assegurando que o sistema de gestão da segurança da informação alcance seus resultados pretendidos;

11225354498 - Maria Vitória Gonçalves Vieira

f) orientando e apoiando pessoas a contribuir para a eficácia do sistema de gestão da segurança da informação;

g) promovendo a melhoria contínua; e

h) apoiando outros papéis relevantes da gestão para demonstrar como sua liderança se aplica às áreas sob sua responsabilidade.

Política

A Alta Direção deve estabelecer uma política de segurança da informação que:

a) seja apropriada ao propósito da organização;

b) inclua os objetivos de segurança da informação ou forneça a estrutura para estabelecer os objetivos de segurança da informação;

c) inclua o comprometimento de satisfazer os requisitos aplicáveis relacionados com a segurança da informação;

d) inclua o comprometimento com a melhoria contínua do sistema de gestão da segurança da informação.

A política da segurança da informação deve:

e) estar disponível como informação documentada;

f) ser comunicada dentro da organização;

g) estar disponível para as partes interessadas, conforme apropriado

Papéis, responsabilidades e autoridades organizacionais

A Alta Direção deve assegurar que as responsabilidades e autoridades dos papéis relevantes para a segurança da informação sejam atribuídos e comunicados dentro da organização.

A Alta Direção deve atribuir a responsabilidade e autoridade para:

11225354498 - Maria Vitória Gonçalves Vieira

a) assegurar que o sistema de gestão da segurança da informação esteja em conformidade com os requisitos deste documento;

b) relatar sobre o desempenho do sistema de gestão da segurança da informação para a Alta Direção

Requisitos do SGSI - Planejamento

Ações para abordar riscos e oportunidades - Geral

Ao planejar o sistema de gestão da segurança da informação, a organização deve considerar as questões gerais da organização e os requisitos estabelecidos, além de determinar os riscos e oportunidades que precisam ser abordados para:

a) assegurar que o sistema de gestão da segurança da informação possa alcançar seus resultados pretendidos;

b) prevenir ou reduzir os efeitos indesejados; e

c) alcançar a melhoria contínua. A organização deve planejar:

d) as ações para abordar estes riscos e oportunidades; e

e) como 1) integrar e implementar as ações dentro dos processos do seu sistema de gestão da segurança da informação; e 2) avaliar a eficácia destas ações

Ações para abordar riscos e oportunidades - Avaliação dos riscos de segurança da informação

A organização deve estabelecer e aplicar um processo de avaliação de riscos de segurança da informação que:

a) estabeleça e mantenha critérios de riscos de segurança da informação que incluam:

1) critérios de aceitação de riscos; e

11225354498 - Maria Vitória Gonçalves Vieira

2) critérios para realizar as avaliações de riscos de segurança da informação;

b) assegure que as contínuas avaliações de riscos de segurança da informação repetidas produzam resultados comparáveis, válidos e consistentes;

c) identifique os riscos de segurança da informação:

1) aplicando o processo de avaliação do risco de segurança da informação para identificar os riscos associados com a perda de confidencialidade, integridade e disponibilidade da informação dentro do escopo do sistema de gestão da segurança da informação; e

2) identificando os proprietários dos riscos.

d) analise os riscos de segurança da informação:

1) avaliando as consequências potenciais que podem resultar se os riscos identificados forem materializados

2) avaliando a probabilidade realística da ocorrência dos riscos identificados; e

3) determinando os níveis de risco

Ações para abordar riscos e oportunidades - Tratamento dos riscos de segurança da informação

A organização deve estabelecer e aplicar um processo de tratamento de riscos da segurança da informação para:

a) selecionar, de forma apropriada, as opções de tratamento dos riscos da segurança da informação, levando em consideração os resultados da avaliação de riscos;

b) determinar todos os controles que são necessários para implementar as opções escolhidas do tratamento de riscos da segurança da informação;

11225354498 - Maria Vitória Gonçalves Vieira

c) comparar os controles determinados com aqueles do Anexo A e verificar se nenhum controle necessário foi omitido;

d) elaborar uma Declaração de Aplicabilidade que contenha:

— os controles necessários
— a justificativa para inclusões;
— se os controles necessários são implementados ou não; e
— a justificativa para a exclusão de quaisquer controles do Anexo A.

e) preparar um plano para tratamento de riscos da segurança da informação; e

f) obter a aprovação dos proprietários dos riscos do plano de tratamento de riscos da segurança da informação e a aceitação dos riscos residuais de segurança da informação.

A organização deve reter a informação documentada relativa ao processo de tratamento de riscos da segurança da informação.

Objetivos da segurança da informação e planejamento para alcançá-los

A organização deve estabelecer os objetivos da segurança da informação para as funções e níveis relevantes.

Os objetivos da segurança da informação devem:

a) ser consistentes com a política da segurança da informação;

b) ser mensuráveis (se praticável);

c) levar em conta os requisitos da segurança da informação aplicáveis e os resultados da avaliação e tratamento de riscos;

d) ser monitorados;

e) ser comunicados;

f) ser atualizados, conforme apropriado;

g) ser disponibilizados como informação documentada.

11225354498 - Maria Vitória Gonçalves Vieira

A organização deve reter informação documentada dos objetivos da segurança da informação. Ao planejar como alcançar os seus objetivos da segurança da informação, a organização deve determinar:

h) o que será feito;

i)quais recursos serão necessários;

j)quem será responsável;

k) quando estará concluído; e

l)como os resultados serão avaliados.

Planejamento de mudanças

Quando a organização determina necessidade para mudanças do sistema de gestão da segurança

da informação, estas mudanças devem ser conduzidas de uma forma planejada.

Requisitos do SGSI - Apoio

Recursos

A organização deve determinar e prover recursos necessários para estabelecer, implementar, manter e melhorar continuamente o sistema de gestão da segurança da informação.

Competência

A organização deve:

a) determinar a competência necessária da(s) pessoa(s) que realiza(m) trabalho sob o seu controle que afete o desempenho da segurança da informação;

B) assegurar que essas pessoas sejam competentes, com base em educação, treinamento ou experiência apropriados;

11225354498 - Maria Vitória Gonçalves Vieira

c) onde aplicável, tomar ações para adquirir a competência necessária e avaliar a eficácia das ações tomadas; e

d) reter informação documentada apropriada como evidência da competência.

Conscientização

Pessoas que realizam trabalho sob o controle da organização devem estar cientes:

a) da política da segurança da informação;

b) da sua contribuição para a eficácia do sistema de gestão da segurança da informação, incluindo os benefícios da melhoria do desempenho da segurança da informação; e

c) das implicações da não conformidade com os requisitos do sistema de gestão da segurança da informação.

Comunicação

A organização deve determinar a necessidade de comunicações internas e externas relevantes para o sistema de gestão da segurança da informação, incluindo:

a) o que comunicar;

b) quando comunicar;

c) com quem comunicar;

d) como se comunicar

Informação Documentada - Geral

O sistema de gestão da segurança da informação da organização deve incluir:

11225354498 - Maria Vitória Gonçalves Vieira

a) informação documentada requerida por este documento; e

b) informação documentada determinada pela organização como sendo necessária para a eficácia do sistema de gestão da segurança da informação.

Informação Documentada - Criando e atualizando

Ao criar e atualizar a informação documentada, a organização deve assegurar, de forma apropriados(as):

a) identificação e descrição (por exemplo, título, data, autor ou um número de referência);

b) formato (por exemplo, linguagem, versão do *software*, gráficos) e seu meio (por exemplo, papel, eletrônico); e

c) análise crítica e aprovação para pertinência e adequação Informação Documentada - Controle de informação documentada

Controle da informação documentada

A informação documentada requerida pelo sistema de gestão da segurança da informação e por este documento deve ser controlada para assegurar que:

a) esteja disponível e adequada para o uso, onde e quando necessário; e

b) esteja protegida adequadamente (por exemplo, contra perda de confidencialidade, uso indevido ou perda de integridade).

11225354498 - Maria Vitória Gonçalves Vieira

Para o controle da informação documentada, a organização deve considerar as seguintes atividades, conforme aplicável:

c) distribuição, acesso, recuperação e uso;

d) armazenamento e preservação, incluindo a preservação da legibilidade;

e) controle de mudanças (por exemplo, controle de versão); e

f) retenção e disposição.

A informação documentada de origem externa, determinada pela organização como necessária para o planejamento e a operação do sistema de gestão da segurança da informação, deve ser identificada como apropriado, e controlada.

Requisitos do SGSI - Operação

Planejamento e controle operacionais

A organização deve planejar, implementar e controlar os processos necessários para atender aos requisitos e para implementar as ações determinadas:

— estabelecendo critérios para os processos;
— implementando controles dos processos de acordo com os critérios.

A informação documentada deve ser disponibilizada na abrangência necessária para gerar a confiança de que os processos estão sendo realizados conforme planejado.

A organização deve controlar as mudanças planejadas e analisar criticamente as consequências de mudanças não intencionais, tomando ações para mitigar quaisquer efeitos adversos, conforme necessário

11225354498 - Maria Vitória Gonçalves Vieira

A organização deve assegurar que os processos, produtos ou serviços providos externamente que são relevantes para o sistema de gestão da segurança da informação sejam controlados.

Avaliação de riscos da segurança da informação

A organização deve realizar avaliações de riscos da segurança da informação a intervalos planejados, ou quando mudanças significativas forem propostas ou ocorrerem.

A organização deve reter informação documentada dos resultados das avaliações de riscos da segurança da informação

Tratamento de riscos da segurança da informação

A organização deve implementar o plano de tratamento de riscos da segurança da informação.

A organização deve reter informação documentada dos resultados do tratamento de riscos da segurança da informação.

Requisitos do SGSI - Avaliação de Desempenho

Monitoramento, medição, análise e avaliação

A organização deve determinar:

a) o que precisa ser monitorado e medido, incluindo processos e controles da segurança da informação;

b) os métodos para monitoramento, medição, análise e avaliação, conforme aplicável, para assegurar resultados válidos. Convém que os métodos selecionados produzam resultados comparáveis e reproduzíveis para serem considerados válidos;

c) quando o monitoramento e a medição devem ser realizados;

d) quem deve monitorar e medir;

e) quando os resultados do monitoramento e da medição devem ser analisados e avaliados;

11225354498 - Maria Vitória Gonçalves Vieira

f) quem deve analisar e avaliar estes resultados.

Informação documentada deve ser disponibilizada como evidência dos resultados.

A organização deve avaliar o desempenho da segurança da informação e a eficácia do sistema de gestão da segurança da informação.

Auditoria Interna - Geral

A organização deve conduzir auditorias internas a intervalos planejados para prover informações sobre se o sistema de gestão da segurança da informação:

a) está em conformidade com:

1) os próprios requisitos da organização para o seu sistema de gestão da segurança da informação;

2) os requisitos deste documento;

b) está efetivamente implementado e mantido.

Auditoria Interna - Programa de Auditoria Interna

A organização deve planejar, estabelecer, implementar e manter programa(s) de auditoria, incluindo frequência, métodos, responsabilidades, requisitos de planejamento e relato.

Ao estabelecer programa(s) de auditoria interna, a organização deve considerar a importância dos processos pertinentes e os resultados de auditorias anteriores.

A organização deve:

a) definir os critérios e o escopo da auditoria, para cada auditoria;

b) selecionar auditores e conduzir auditorias que assegurem objetividade e imparcialidade

do processo de auditoria;

c) assegurar que os resultados das auditorias sejam relatados para a gestão pertinente.

11225354498 - Maria Vitória Gonçalves Vieira

Informação documentada deve ser disponibilizada como evidência da implementação do(s) programa(s) de auditoria e dos resultados da auditoria.

Análise Crítica pela Direção - Geral

A Alta Direção deve analisar criticamente o sistema de gestão da segurança da informação da organização em intervalos planejados, para assegurar a sua contínua adequação, pertinência e eficácia.

Análise Crítica pela Direção - Entradas da análise crítica pela Direção

A análise crítica pela Direção deve incluir considerações em relação a:

a) situação das ações de análises críticas anteriores pela Direção;

b) mudanças nas questões internas e externas que sejam relevantes para o sistema de gestão da segurança da informação;

c) mudanças nas necessidades e expectativas das partes interessadas que sejam relevantes para o sistema de gestão da segurança da informação

d) *feedback* sobre o desempenho da segurança da informação, incluindo tendências para:

1) não conformidades e ações corretivas;

2) resultados da medição e monitoramento;

3) resultados de auditorias;

4) cumprimento dos objetivos da segurança da informação;

e) *feedback* das partes interessadas;

F) resultados da avaliação dos riscos e situação do plano de tratamento de riscos;

g) oportunidades para a melhoria contínua

Análise Crítica pela Direção - Resultados da análise crítica pela Direção

Os resultados da análise crítica pela Direção devem incluir decisões relativas às oportunidades para melhoria contínua e quaisquer necessidades de mudanças do sistema de gestão da segurança da informação.

11225354498 - Maria Vitória Gonçalves Vieira

Informação documentada deve ser disponibilizada como evidência dos resultados das análises críticas pela Direção

Requisitos do SGSI - Melhoria

Melhoria contínua

A organização deve melhorar continuamente a pertinência, a adequação e a eficácia do sistema de gestão da segurança da informação

Não conformidade e ação corretiva

Quando uma não conformidade ocorre, a organização deve:

a) reagir à não conformidade e, conforme apropriado:

1) tomar ações para controlá-la e corrigi-la; e

2) lidar com as consequências;

b) avaliar a necessidade de ações para eliminar as causas de não conformidade, para evitar sua repetição ou ocorrência em outro lugar, por um dos seguintes meios:

1) analisando criticamente a não conformidade;

2) determinando as causas da não conformidade; e

3) determinando se não conformidades similares existem, ou se podem potencialmente ocorrer;

c) implementar quaisquer ações necessárias;

d) analisar criticamente a eficácia de quaisquer ações corretivas tomadas; e

e) realizar mudanças no sistema de gestão da segurança da informação, quando necessário. As ações corretivas devem ser apropriadas aos efeitos das não conformidades encontradas.

Informação documentada deve estar disponível como evidência de:



11225354498 - Maria Vitória Gonçalves Vieira

f) natureza das não conformidades e quaisquer ações subsequentes tomadas; e

g) resultados de qualquer ação corretiva.

Controles (Anexo A)

Os objetivos de controle e controles listados na tabela seguinte não são exaustivos e uma organização pode considerar que objetivos de controle e controles adicionais são necessários. As provas costumam cobrar a literalidade da norma. Na minha opinião, tentar decorar tudo isso é contraproducente. Sugiro ler e reler diversas vezes até começar a absorver naturalmente – tentando entender em vez de memorizar.

Controles organizacionais	
Políticas de segurança da informação	**Controle** A política de segurança da informação e as políticas específicas por tema devem ser definidas, aprovadas pela direção, publicadas, comunicadas e reconhecidas pelo pessoal pertinente e pelas partes interessadas pertinentes, e analisadas criticamente em intervalos planejados e quando ocorrerem mudanças significativas.
Papéis e responsabilidades pela segurança da informação	**Controle** Papéis e responsabilidades pela segurança da informação devem ser definidos e alocados de acordo com as necessidades da organização.
Segregação de funções	**Controle** Funções conflitantes e áreas de responsabilidade conflitantes devem ser segregadas.
Responsabilidades da direção	**Controle** A direção deve requerer que todo o pessoal aplique a segurança da informação de acordo com a política da segurança da informação estabelecida, com as políticas específicas por tema e com os procedimentos da organização.
Contato com autoridades	**Controle** A organização deve estabelecer e manter contato com as

11225354498 - Maria Vitória Gonçalves Vieira

	autoridades relevantes.
Contato com grupos de interesse especial	**Controle** A organização deve estabelecer e manter contato com grupos de interesse especial ou com outros fóruns de especialistas em segurança e associações profissionais.
Inteligência de ameaças	**Controle** As informações relacionadas a ameaças à segurança da informação devem ser coletadas e analisadas para produzir inteligência de ameaças.
Segurança da informação no gerenciamento de projetos	Controle A segurança da informação deve ser integrada ao gerenciamento de projetos.
Inventário de informações e outros ativos associados	Controle Um inventário de informações e outros ativos associados, incluindo proprietários, deve ser desenvolvido e mantido.
Uso aceitável de informações e outros ativos associados	Controle Regras para o uso aceitável e procedimentos para o manuseio de informações e outros ativos associados devem ser identificados, documentados e implementados.
Devolução de ativos	Controle O pessoal e outras partes interessadas, conforme apropriado, devem devolver todos os ativos da organização em sua posse em mudança ou o encerramento de seu emprego, contratação ou acordo.
Classificação das informações	Controle As informações devem ser classificadas de acordo com as necessidades de segurança da informação da organização, com base na confidencialidade, integridade, disponibilidade e requisitos das partes interessadas relevantes.

11225354498 - Maria Vitória Gonçalves Vieira

Rotulagem de informações	Controle Um conjunto adequado de procedimentos para rotulagem de informações deve ser desenvolvido e implementado de acordo com o esquema de classificação de informações adotado pela organização.
Transferência de informações	Controle Regras, procedimentos ou acordos de transferência de informações devem ser implementados para todos os tipos de recursos de transferência dentro da organização e entre a organização e outras partes.
Controle de acesso	Controle Regras para controlar o acesso físico e lógico às informações e a outros ativos associados devem ser estabelecidas e implementadas com base nos requisitos de segurança da informação e de negócios.
Gestão de identidade	Controle O ciclo de vida completo das identidades deve ser gerenciado.
Informações de autenticação	Controle A alocação e a gestão de informações de autenticação devem ser controladas por um processo de gestão, incluindo aconselhar o pessoal sobre o manuseio adequado de informações de autenticação.
Direitos de acesso	Controle Os direitos de acesso às informações e a outros ativos associados devem ser provisionados, analisados criticamente, modificados e removidos de acordo com a política específica por tema e com as regras da organização para o controle de acesso.
Segurança da informação nas relações com fornecedores	Controle Processos e procedimentos devem ser definidos e implementados para gerenciar os riscos da segurança da informação associados com o uso dos produtos ou serviços dos fornecedores.



Abordagem da segurança da informação nos contratos de fornecedores	Controle Requisitos relevantes de segurança da informação devem ser estabelecidos e acordados com cada fornecedor, com base no tipo de relacionamento com o fornecedor.
Gestão da segurança da informação na cadeia de fornecimento de tecnologia de informação e comunicação (TIC)	Controle Processos e procedimentos devem ser definidos e implementados para gerenciar os riscos da segurança da informação associados à cadeia de fornecimento de produtos e serviços de TIC.
Monitoramento, análise crítica e gestão de mudanças dos serviços de fornecedores	Controle A organização deve monitorar, analisar criticamente, avaliar e gerenciar regularmente a mudança nas práticas da segurança da informação dos fornecedores e na prestação de serviços.
Segurança da informação para uso de serviços em nuvem	Controle Os processos de aquisição, uso, gestão e saída de serviços em nuvem devem ser estabelecidos de acordo com os requisitos da segurança da informação da organização.
Planejamento e preparação da gestão de incidentes da segurança da informação	Controle A organização deve planejar e se preparar para gerenciar incidentes da segurança da informação, definindo, estabelecendo e comunicando processos, papéis e responsabilidades de gestão de incidentes da segurança da informação.
Avaliação e decisão sobre eventos da segurança da informação	Controle A organização deve avaliar os eventos da segurança da informação e decidir se categoriza como incidentes da segurança da informação.
Resposta a incidentes da segurança da informação	Controle Os incidentes da segurança da informação devem ser respondidos de acordo com os procedimentos documentados.

11225354498 - Maria Vitória Gonçalves Vieira

Aprendizado com incidentes de segurança da informação	Controle O conhecimento adquirido com incidentes de segurança da informação deve ser usado para fortalecer e melhorar os controles da segurança da informação.
Coleta de evidências	Controle A organização deve estabelecer e implementar procedimentos para identificação, coleta, aquisição e preservação de evidências relacionadas a eventos da segurança da informação.
Segurança da informação durante a disrupção	Controle A organização deve planejar como manter a segurança da informação em um nível apropriado durante a disrupção.
Prontidão de TIC para continuidade de negócios	Controle A prontidão de TIC deve ser planejada, implementada, mantida e testada com base nos objetivos de continuidade de negócios e nos requisitos de continuidade da TIC.
Requisitos legais, estatutários, regulamentares e contratuais	Controle Os requisitos legais, estatutários, regulamentares e contratuais pertinentes à segurança da informação e a abordagem da organização para atender a esses requisitos devem ser identificados, documentados e atualizados.
Direitos de propriedade intelectual	Controle A organização deve implementar procedimentos adequados para proteger os direitos de propriedade intelectual.
Proteção de registros	Controle Os registros devem ser protegidos contra perdas, destruição, falsificação, acesso não autorizado e liberação não autorizada.

11225354498 - Maria Vitória Gonçalves Vieira

Privacidade e proteção de DP	Controle A organização deve identificar e atender aos requisitos relativos à preservação da privacidade e à proteção de DP, de acordo com as leis e os regulamentos aplicáveis e requisitos contratuais.
Análise crítica independente da segurança da informação	Controle A abordagem da organização para gerenciar a segurança da informação e sua implementação, incluindo pessoas, processos e tecnologias, devem ser analisadas criticamente, de forma independente a intervalos planejados ou quando ocorrerem mudanças significativas.
Compliance com políticas, regras e normas para segurança da informação	Controle O *compliance* com a política de segurança da informação da organização, políticas específicas por tema, regras e normas deve ser analisado criticamente a intervalos regulares.
Documentação dos procedimentos de operação	Controle Os procedimentos de operação dos recursos de processamento das informações devem ser documentados e disponibilizados para o pessoal que necessite deles.

Controles de pessoas	
Seleção	**Controle** Verificações de antecedentes de todos os candidatos a serem contratados devem ser realizadas antes de ingressarem na organização e de modo contínuo, de acordo com as leis, os regulamentos e a ética aplicáveis, e devem ser proporcionais aos requisitos do negócio, à classificação das informações a serem acessadas e aos riscos percebidos.

Termos e condições de contratação	**Controle** Os contratos trabalhistas devem declarar as responsabilidades do pessoal e da organização para a segurança da informação.
Conscientização, educação e treinamento em segurança da informação	**Controle** O pessoal da organização e partes interessadas relevantes devem receber treinamento, educação e conscientização em segurança da informação apropriados e atualizações regulares da política de segurança da informação da organização, políticas específicas por tema e procedimentos, conforme pertinente para as suas funções.
Processo disciplinar	Controle Um processo disciplinar deve ser formalizado e comunicado, para tomar ações contra pessoal e outras partes interessadas relevantes que tenham cometido uma violação da política da segurança da informação.
Responsabilidades após encerramento ou mudança da contratação	Controle As responsabilidades e funções de segurança da informação que permaneçam válidas após o encerramento ou a mudança da contratação devem ser definidas, aplicadas e comunicadas ao pessoal e a outras partes interessadas pertinentes.
Acordos de confidencialidade ou não divulgação	Controle Acordos de confidencialidade ou não divulgação que reflitam as necessidades da organização para a proteção das informações devem ser identificados, documentados, analisados criticamente em intervalos regulares e assinados pelo pessoal e por outras partes interessadas pertinentes.
Trabalho remoto	Controle Medidas de segurança devem ser implementadas quando as pessoas estiverem trabalhando remotamente para proteger as informações acessadas, tratadas ou armazenadas fora das instalações da organização.
Relato de eventos de segurança da informação	Controle A organização deve fornecer um mecanismo para que as pessoas relatem eventos da segurança da informação observados ou suspeitos por meio de canais apropriados

11225354498 - Maria Vitória Gonçalves Vieira

	em tempo hábil.

Controles físicos	
Perímetros de segurança física	**Controle** Perímetros de segurança devem ser definidos e usados para proteger áreas que contenham informações e outros ativos associados.
Entrada física	**Controle** As áreas seguras devem ser protegidas por controles de entrada e pontos de acesso apropriados.
Segurança de escritórios, salas e instalações	**Controle** Segurança física para escritórios, salas e instalações deve ser projetada e implementada
Monitoramento de segurança física	**Controle** As instalações devem ser monitoradas continuamente quanto a acesso físico não autorizado
Proteção contra ameaças físicas e ambientais	**Controle** Proteção contra ameaças físicas e ambientais, como desastres naturais e outras ameaças físicas intencionais ou não intencionais à infraestrutura, deve ser projetada e implementada.
Trabalho em áreas seguras	**Controle** Medidas de segurança para trabalhar em áreas seguras devem ser projetadas e implementadas.
Mesa limpa e tela limpa	**Controle** Regras de mesa limpa para documentos impressos e mídia de armazenamento removível e regras de tela limpa para os recursos de processamento de informações devem ser definidas e adequadamente aplicadas.
Localização e proteção de equipamentos	**Controle** Os equipamentos devem ser posicionados com segurança e proteção.

Segurança de ativos fora das instalações da organização	**Controle** Os ativos fora das instalações da organização devem ser protegidos.
Mídia de armazenamento	**Controle** As mídias de armazenamento devem ser gerenciadas por seu ciclo de vida de aquisição, uso, transporte e descarte, de acordo com o esquema de classificação e com os requisitos de manuseio da organização.
Serviços de infraestrutura	**Controle** As instalações de processamento de informações devem ser protegidas contra falhas de energia e outras disrupções causadas por falhas nos serviços de infraestrutura.
Segurança do cabeamento	**Controle** Os cabos que transportam energia ou dados, ou que sustentam serviços de informação, devem ser protegidos contra interceptação, interferência ou danos.
Manutenção de equipamentos	**Controle** Os equipamentos devem ser mantidos corretamente para assegurar a disponibilidade, integridade e confidencialidade da informação.
Descarte seguro ou reutilização de equipamentos	**Controle** Os itens dos equipamentos que contenham mídia de armazenamento devem ser verificados para assegurar que quaisquer dados sensíveis e *software* licenciado tenham sido removidos ou sobrescritos com segurança antes do descarte ou reutilização.

Controles tecnológicos	
Dispositivos *endpoint* do usuário	**Controle** Informações armazenadas, processadas ou acessíveis por meio de dispositivos *endpoint* do usuário devem ser protegidas.

11225354498 - Maria Vitória Gonçalves Vieira

Direitos de acessos privilegiados	**Controle** A atribuição e o uso de direitos de acessos privilegiados devem ser restritos e gerenciados
Restrição de acesso à informação	**Controle** O acesso às informações e a outros ativos associados deve ser restrito de acordo com a política específica por tema sobre controle de acesso.
Acesso ao código-fonte	**Controle** Os acessos de leitura e escrita ao código-fonte, ferramentas de desenvolvimento e bibliotecas de *software* devem ser adequadamente gerenciados.
Autenticação segura	**Controle** Tecnologia e procedimentos de autenticação segura devem ser implementados, com base em restrições de acesso à informação e à política específica por tema de controle de acesso.
Gestão de capacidade	**Controle** O uso dos recursos deve ser monitorado e ajustado de acordo com os requisitos de capacidade atual e esperada.
Proteção contra *malware*	**Controle** Proteção contra *malware* deve ser implementada e apoiada pela conscientização adequada do usuário.
Gestão de vulnerabilidades técnicas	**Controle** Informações sobre vulnerabilidades técnicas dos sistemas de informação em uso devem ser obtidas; a exposição da organização a tais vulnerabilidades deve ser avaliada e medidas apropriadas devem ser tomadas
Gestão de configuração	**Controle** As configurações, incluindo configurações de segurança, de hardware, software, serviços e redes, devem ser estabelecidas, documentadas, implementadas, monitoradas e analisadas criticamente.

11225354498 - Maria Vitória Gonçalves Vieira

Exclusão de informações	**Controle** As informações armazenadas em sistemas de informação, dispositivos ou em qualquer outra mídia de armazenamento devem ser excluídas quando não forem mais necessárias.
Mascaramento de dados	**Controle** O mascaramento de dados deve ser usado de acordo com a política específica por tema da organização sobre o controle de acesso e outras políticas específicas por tema relacionadas e requisitos do negócio, levando em consideração a legislação aplicável.
Prevenção de vazamento de dados	**Controle** As medidas de prevenção de vazamento de dados devem ser aplicadas a sistemas, redes e quaisquer outros dispositivos que processem, armazenem ou transmitam informações sensíveis.
Backup das informações	**Controle** Cópias de backup de informações, software e sistemas devem ser mantidas e testadas regularmente de acordo com a política específica por tema acordada sobre backup.
Redundância dos recursos de processamento de informações	**Controle** Recursos de processamento de informações devem ser implementados com redundância suficiente para atender aos requisitos de disponibilidade.
Log	**Controle** Logs que registrem atividades, exceções, falhas e outros eventos relevantes devem ser produzidos, armazenados, protegidos e analisados.
Atividades de monitoramento	**Controle** As redes, sistemas e aplicações devem ser monitorados quanto a comportamentos anômalos e ações apropriadas devem ser tomadas para avaliar possíveis incidentes de segurança da informação.
Princípios de arquitetura e engenharia de sistemas seguros	**Controle** Princípios para engenharia de sistemas seguros devem ser estabelecidos, documentados, mantidos e aplicados a qualquer atividade de desenvolvimento de sistemas.

Codificação segura	**Controle** Princípios de codificação segura devem ser aplicados ao desenvolvimento de software.
Testes de segurança em desenvolvimento e aceitação	**Controle** Processos de teste de segurança devem ser definidos e implementados no ciclo de vida do desenvolvimento.
Desenvolvimento terceirizado	**Controle** A organização deve dirigir, monitorar e analisar criticamente as atividades relacionadas à terceirização de desenvolvimento de sistemas.
Separação dos ambientes de desenvolvimento, teste e produção	**Controle** Ambientes de desenvolvimento, testes e produção devem ser separados e protegidos.
Gestão de mudanças	**Controle** Mudanças nos recursos de tratamento de informações e sistemas de informação devem estar sujeitas a procedimentos de gestão de mudanças.
Informações de teste	**Controle** Informações de teste devem ser adequadamente selecionadas, protegidas e gerenciadas.
Proteção de sistemas de informação durante os testes de auditoria	**Controle** Testes de auditoria e outras atividades de garantia envolvendo a avaliação de sistemas operacionais devem ser planejados e acordados entre o testador e a gestão apropriada.

APOSTA ESTRATÉGICA

A ideia desta seção é apresentar os pontos do conteúdo que mais possuem chances de serem cobrados em prova, considerando o histórico de questões da banca em

provas de nível semelhante à nossa, bem como as inovações no conteúdo, na legislação e nos entendimentos doutrinários e jurisprudenciais[1].

A gestão da continuidade do negócio, conforme delineada na ISO 27001, é uma área essencial que assegura a capacidade de uma organização para continuar operando durante e após um incidente ou crise. Este aspecto da segurança da informação não trata apenas de prevenir interrupções, mas também de planejar respostas eficazes que permitam a recuperação rápida e eficiente das operações críticas. Tal planejamento envolve a identificação das funções críticas do negócio, a avaliação dos riscos que podem causar interrupções nessas funções e o desenvolvimento de estratégias que possibilitem a continuação ou recuperação rápida das operações.

O processo de avaliação e tratamento de riscos, como parte da implementação de um Sistema de Gestão de Segurança da Informação (SGSI) de acordo com a ISO 27001, serve para garantir que a organização possa identificar, quantificar e, mais importante, gerenciar os riscos relacionados à segurança da informação. A avaliação de riscos obriga a organização a olhar detalhadamente para suas vulnerabilidades e ameaças potenciais, e a analisar como esses fatores poderiam impactar suas operações e objetivos estratégicos. Com base nesta avaliação, a organização pode então priorizar os riscos e aplicar os controles adequados para mitigá-los, ajustando esses controles conforme necessário para responder a mudanças no ambiente operacional ou no panorama de ameaças.

Questões Estratégicas

Nesta seção, apresentamos e comentamos uma amostra de questões objetivas selecionadas estrategicamente: são questões com nível de dificuldade semelhante ao que você deve esperar para a sua prova e que, em conjunto, abordam os principais pontos do assunto.

A ideia, aqui, não é que você fixe o conteúdo por meio de uma bateria extensa de questões, mas que você faça uma boa revisão global do assunto a partir de, relativamente, poucas questões

1. (FGV / IMBEL – 2021) A Associação Brasileira de Normas Técnicas, ABNT, é responsável pela elaboração das Normas Brasileiras como, por exemplo, a ABNT NBR ISO/IEC 27001:2013, sobre aspectos da Segurança da Informação.

[1] Vale deixar claro que nem sempre será possível realizar uma aposta estratégica para um determinado assunto, considerando que às vezes não é viável identificar os pontos mais prováveis de serem cobrados a partir de critérios objetivos ou minimamente razoáveis.

Dado que a sigla ISO deriva de International Organization for Standardization, assinale a correta natureza das normas NBR ISO.

a) São normas brasileiras que passam a ser adotadas pela ISO.
b) São normas definidas em conjunto com a ISO.
c) São traduções de normas da ISO que passam a ser adotadas pela ABNT.
d) São normas da ISO adaptadas pela ABNT às práticas brasileiras.
e) São normas brasileiras compiladas a partir da combinação de outras normas da ISO.

Comentários: Quando vemos uma norma ISO/IEC com o prefixo ABNT NBR significa que se trata de uma tradução que passa a ser adotada pela ABNT.

Gabarito: Letra C

2. (FGV / MPE-AL – 2018) Assinale a opção que melhor descreve o princípio geral da norma ISO/IEC 27001.

a) Definir os procedimentos e tarefas adequados à mitigação de riscos no âmbito de um sistema de gestão de segurança da informação.
b) Definir os requisitos necessários para estabelecer, implementar, manter e melhorar de forma contínua um sistema de gestão de segurança da informação.
c) Estabelecer os papéis, responsabilidades e atuação dos profissionais de segurança da informação numa organização.
d) Orientar e alertar as organizações e seus respectivos profissionais em diversos aspectos relativos à gestão de segurança da informação.
e) Prover uma coleção de artefatos tecnológicos que permitam a identificação, avaliação e eliminação de ataques aos ativos de segurança da informação.

Comentários: A primeira frase contida na norma é: Esta Norma foi preparada para prover requisitos para estabelecer, implementar, manter e melhorar continuamente um Sistema de Gestão de Segurança da Informação (SGSI).

Gabarito: Letra B

3. (FGV / BANESTES – 2018) A adoção de um Sistema de Gestão de Segurança da Informação (SGSI) é uma decisão estratégica para as organizações. De acordo com a norma ABNT NBR ISO/IEC 27001:2013, quando ocorre uma não conformidade no SGSI, a organização deve:

a) evitar reagir à não conformidade de modo a controlá-la ou corrigi-la;
b) aceitar que impactos adversos podem ocorrer na operação e esperar que não volte a se repetir;

11225354498 - Maria Vitória Gonçalves Vieira

c) impedir mudanças no Sistema de Gestão de Segurança da Informação para assegurar que auditorias internas possam ser realizadas;
d) determinar se não conformidades similares existem, ou podem potencialmente ocorrer;
e) forçar sua repetição ou ocorrência para comunicar às partes interessadas de forma apropriada.

Comentários: 10.1 Não conformidade e ação corretiva Quando uma não conformidade ocorre, a organização deve: (...) b) avaliar a necessidade de ações para eliminar as causas de não conformidade, para evitar sua repetição ou ocorrência, por um dos seguintes meios: (...) 3) determinando se não conformidades similares existem, ou podem potencialmente ocorrer.

Gabarito: Letra D

4. (FGV / IBGE – 2017) Uma empresa deseja ser certificada na implementação da norma ISO 27001. Para tal, ela deve seguir com rigor o que preconiza a norma, como por exemplo:

a) selecionar as partes da norma aplicáveis à empresa, recebendo assim a certificação apenas sobre essas partes implementadas;
b) realizar previamente uma análise de risco com abordagem quantitativa;
c) definir uma política de segurança com base no uso efetivo de um conjunto técnico de ferramentas, de reconhecida eficiência;
d) garantir que os gestores de segurança realizem análises críticas do SGSI em intervalos regulares;
e) justificar, na declaração de aplicabilidade, o motivo da não utilização de controles listados na própria norma.

Comentários: (a) Errado, a exclusão de quaisquer dos requisitos especificados não é aceitável quando a organização busca a conformidade com a norma; (b) Errado, isso não se encontra na norma; (c) Errado, isso não se encontra na norma; (d) Errado, a norma cita que os gestores devem analisar criticamente, a intervalos regulares, a conformidade dos procedimentos e do processamento da informação, dentro das suas áreas de responsabilidade, com as normas e políticas de segurança e quaisquer outros requisitos de segurança da informação; (e) Correto, a norma afirma que A organização deve definir e aplicar um processo de tratamento dos riscos de segurança da informação para elaborar uma declaração de aplicabilidade que contenha os controles necessários e a justificativa para inclusões, sejam eles implementados ou não, bem como a justificativa para a exclusão dos controles.

11225354498 - Maria Vitória Gonçalves Vieira

Gabarito: Letra E

5. (FGV / TJDFT – Análise de Sistemas – 2022) Durante uma auditoria externa contratada pelo Tribunal de Justiça ao departamento de segurança da informação, foram avaliados os sistemas existentes seguindo a Norma ABNT NBR ISO/IEC 27001. Durante a avaliação, houve a necessidade de prover um sistema de gerenciamento de senhas interativo e com qualidade. Para criar o seu sistema, o departamento de segurança deve fazer uso do objetivo de controle:

   a) requisitos do negócio para controle de acesso;

   b) controle de acesso ao sistema e à aplicação;

   c) responsabilidade pelos ativos;

   d) segurança em recursos humanos;

   e) gerenciamento de acesso do usuário.

Comentários:

A.9.4 – controle de acesso ao sistema e à aplicação		
Objetivo: prevenir o acesso não autorizado aos sistemas e aplicações.		
A.9.3.1	Restrição de acesso à informação	Controle: o acesso à informação e as funções dos sistemas de aplicações devem ser restrito de acordo com a política de controle de acesso.
A.9.3.2	Procedimentos seguros de entrada no sistema (log-on)	Controle: onde aplicável pela política de controle de acesso, o acesso aos sistemas e aplicações devem ser

11225354498 - Maria Vitória Gonçalves Vieira

		controlados por um procedimento seguro de entrada no sistema (log-on).
A.9.3.3	Sistema de gerenciamento de senha	**Controle:** sistemas para gerenciamento de senhas devem ser interativos e devem assegurar senhas de qualidade.
A.9.3.4	Uso de programas utilitários privilegiados	**Controle:** o uso de programas utilitários que podem ser capazes de sobrepor os controles dos sistemas e aplicações deve ser restrito e estritamente controlado.
A.9.3.5	Controle de acesso ao código-fonte de programas	**Controle:** o acesso ao código-fonte de programa deve ser restrito.

Gabarito: Letra B

QUESTIONÁRIO DE REVISÃO E APERFEIÇOAMENTO

A ideia do questionário é elevar o nível da sua compreensão no assunto e, ao mesmo tempo, proporcionar uma outra forma de revisão de pontos importantes do conteúdo, a partir de perguntas que exigem respostas subjetivas.

São questões um pouco mais desafiadoras, porque a redação de seu enunciado não ajuda na sua resolução, como ocorre nas clássicas questões objetivas.

O objetivo é que você realize uma auto explicação mental de alguns pontos do conteúdo, para consolidar melhor o que aprendeu ;)

Além disso, as questões objetivas, em regra, abordam pontos isolados de um dado assunto. Assim, ao resolver várias questões objetivas, o candidato acaba memorizando

pontos isolados do conteúdo, mas muitas vezes acaba não entendendo como esses pontos se conectam.

Assim, no questionário, buscaremos trazer também situações que ajudem você a conectar melhor os diversos pontos do conteúdo, na medida do possível.

É importante frisar que não estamos adentrando em um nível de profundidade maior que o exigido na sua prova, mas apenas permitindo que você compreenda melhor o assunto de modo a facilitar a resolução de questões objetivas típicas de concursos, ok?

Nosso compromisso é proporcionar a você uma revisão de alto nível!

Vamos ao nosso questionário:

Perguntas

1. O que é a norma ISO 27001?
2. De que norma a ISO 27001 se originou?
3. Quais são os principais benefícios da implementação da ISO 27001?
4. O que é incluído no escopo da ISO 27001?
5. O que é confidencialidade no contexto de segurança da informação?
6. Como a integridade dos dados é garantida em segurança da informação?
7. O que é disponibilidade em segurança da informação?
8. Qual é a importância da autenticidade em segurança da informação?
9. Como a irretratabilidade é assegurada em segurança da informação?
10. Quais são as principais ameaças à segurança da informação?
11. O que é um Sistema de Gestão de Segurança da Informação (SGSI)?
12. Como uma organização pode se preparar para a certificação ISO 27001?
13. O que é a ISO 27002 e como ela se relaciona com a ISO 27001?
14. O que acontece se a confidencialidade das informações for violada?
15. Como a integridade pode ser comprometida?
16. O que pode afetar a disponibilidade das informações?
17. Por que a autenticidade é importante na segurança da informação?
18. O que pode acontecer se a irretratabilidade não for assegurada?
19. O que são controles de segurança da informação na ISO 27001?
20. Por que a melhoria contínua é importante para a ISO 27001?

Perguntas e Respostas

1. O que é a norma ISO 27001?
   Resposta: A ISO 27001 é uma norma internacional que fornece o quadro para a implementação, operação, monitoramento, revisão, manutenção e melhoria de um Sistema de Gestão de Segurança da Informação (SGSI).
2. De que norma a ISO 27001 se originou?
   Resposta: A ISO 27001 originou-se da norma britânica BS 7799.
3. Quais são os principais benefícios da implementação da ISO 27001?
   Resposta: A implementação da ISO 27001 ajuda a proteger informações confidenciais, aumentar a resiliência aos ataques cibernéticos, melhorar a reputação da empresa, garantir a conformidade com requisitos diversos e reduzir incidentes de segurança da informação.
4. O que é incluído no escopo da ISO 27001?
   Resposta: O escopo da ISO 27001 abrange a implementação e manutenção de um SGSI, incluindo a avaliação e o tratamento de riscos de segurança da informação e a implementação de controles de segurança da informação adequados.
5. O que é confidencialidade no contexto de segurança da informação?
   Resposta: A confidencialidade refere-se à proteção das informações contra o acesso e divulgação não autorizados.
6. Como a integridade dos dados é garantida em segurança da informação?
   Resposta: A integridade dos dados é garantida protegendo-os contra alteração, exclusão ou corrupção não autorizadas.
7. O que é disponibilidade em segurança da informação?
   Resposta: Disponibilidade refere-se à garantia de que as informações estejam acessíveis para usuários autorizados quando necessário.
8. Qual é a importância da autenticidade em segurança da informação?
   Resposta: A autenticidade é importante porque garante que as partes envolvidas em uma comunicação ou transação sejam de fato quem afirmam ser.
9. Como a irretratabilidade é assegurada em segurança da informação?
   Resposta: A irretratabilidade é frequentemente assegurada através de mecanismos como registros de log detalhados e assinaturas digitais.
10. Quais são as principais ameaças à segurança da informação?
    Resposta: As principais ameaças à segurança da informação incluem ataques cibernéticos, vazamentos de dados, falhas humanas, desastres naturais, entre outros.
11. O que é um Sistema de Gestão de Segurança da Informação (SGSI)?
    Resposta: Um SGSI é um sistema para gerenciar a segurança da informação de uma organização através de um processo de gestão de riscos e um conjunto de controles de segurança.

11225354498 - Maria Vitória Gonçalves Vieira

12. Como uma organização pode se preparar para a certificação ISO 27001?
    Resposta: A organização deve implementar um SGSI de acordo com os requisitos da ISO 27001, conduzir uma auditoria interna, e em seguida passar por uma auditoria de certificação conduzida por um organismo de certificação externo.
13. O que é a ISO 27002 e como ela se relaciona com a ISO 27001?
    Resposta: A ISO 27002 é uma norma que oferece diretrizes para controles de segurança da informação. Ela funciona como um guia de apoio à implementação de um SGSI conforme a ISO 27001.
14. O que acontece se a confidencialidade das informações for violada?
    Resposta: Se a confidencialidade das informações for violada, os dados podem ser acessados ou divulgados de forma não autorizada, o que pode levar a danos financeiros, perda de reputação e problemas legais.
15. Como a integridade pode ser comprometida?
    Resposta: A integridade pode ser comprometida através de alteração, exclusão ou corrupção não autorizadas dos dados.
16. O que pode afetar a disponibilidade das informações?
    Resposta: A disponibilidade das informações pode ser afetada por interrupções dos sistemas, seja devido a ataques cibernéticos, falhas de sistema, desastres naturais ou falhas humanas.
17. Por que a autenticidade é importante na segurança da informação?
    Resposta: A autenticidade é importante para prevenir ações de usurpação de identidade e acessos não autorizados, garantindo que as partes envolvidas em uma comunicação ou transação sejam de fato quem afirmam ser.
18. O que pode acontecer se a irretratabilidade não for assegurada?
    Resposta: Se a irretratabilidade não for assegurada, um usuário pode negar a autoria de uma ação que realizou, o que pode levar a problemas de responsabilidade e confiança.
19. O que são controles de segurança da informação na ISO 27001?
    Resposta: Controles de segurança da informação na ISO 27001 são medidas recomendadas para a proteção de informações, incluindo políticas de segurança, organização da segurança da informação, gestão de ativos, controle de acesso, segurança física e do ambiente, entre outros.
20. Por que a melhoria contínua é importante para a ISO 27001?
    Resposta: A melhoria contínua é importante para a ISO 27001 porque a segurança da informação não é um estado estático. As ameaças evoluem, assim como a organização e a tecnologia. Portanto, é necessário revisar e melhorar continuamente o SGSI para garantir que ele permaneça eficaz.

11225354498 - Maria Vitória Gonçalves Vieira

Lista de Questões Estratégicas

1. (FGV / IMBEL – 2021) A Associação Brasileira de Normas Técnicas, ABNT, é responsável pela elaboração das Normas Brasileiras como, por exemplo, a ABNT NBR ISO/IEC 27001:2013, sobre aspectos da Segurança da Informação.
Dado que a sigla ISO deriva de International Organization for Standardization, assinale a correta natureza das normas NBR ISO.

a) São normas brasileiras que passam a ser adotadas pela ISO.
b) São normas definidas em conjunto com a ISO.
c) São traduções de normas da ISO que passam a ser adotadas pela ABNT.
d) São normas da ISO adaptadas pela ABNT às práticas brasileiras.
e) São normas brasileiras compiladas a partir da combinação de outras normas da ISO.

2. (FGV / MPE-AL – 2018) Assinale a opção que melhor descreve o princípio geral da norma ISO/IEC 27001.

a) Definir os procedimentos e tarefas adequados à mitigação de riscos no âmbito de um sistema de gestão de segurança da informação.
b) Definir os requisitos necessários para estabelecer, implementar, manter e melhorar de forma contínua um sistema de gestão de segurança da informação.
c) Estabelecer os papéis, responsabilidades e atuação dos profissionais de segurança da informação numa organização.
d) Orientar e alertar as organizações e seus respectivos profissionais em diversos aspectos relativos à gestão de segurança da informação.
e) Prover uma coleção de artefatos tecnológicos que permitam a identificação, avaliação e eliminação de ataques aos ativos de segurança da informação.

3. (FGV / BANESTES – 2018) A adoção de um Sistema de Gestão de Segurança da Informação (SGSI) é uma decisão estratégica para as organizações. De acordo com a norma ABNT NBR ISO/IEC 27001:2013, quando ocorre uma não conformidade no SGSI, a organização deve:

a) evitar reagir à não conformidade de modo a controlá-la ou corrigi-la;
b) aceitar que impactos adversos podem ocorrer na operação e esperar que não volte a se repetir;
c) impedir mudanças no Sistema de Gestão de Segurança da Informação para assegurar que auditorias internas possam ser realizadas;
d) determinar se não conformidades similares existem, ou podem potencialmente ocorrer;

11225354498 - Maria Vitória Gonçalves Vieira

e) forçar sua repetição ou ocorrência para comunicar às partes interessadas de forma apropriada.

4. (FGV / IBGE – 2017) Uma empresa deseja ser certificada na implementação da norma ISO 27001. Para tal, ela deve seguir com rigor o que preconiza a norma, como por exemplo:

a) selecionar as partes da norma aplicáveis à empresa, recebendo assim a certificação apenas sobre essas partes implementadas;
b) realizar previamente uma análise de risco com abordagem quantitativa;
c) definir uma política de segurança com base no uso efetivo de um conjunto técnico de ferramentas, de reconhecida eficiência;
d) garantir que os gestores de segurança realizem análises críticas do SGSI em intervalos regulares;
e) justificar, na declaração de aplicabilidade, o motivo da não utilização de controles listados na própria norma.

5. (FGV / TJDFT – Análise de Sistemas – 2022) Durante uma auditoria externa contratada pelo Tribunal de Justiça ao departamento de segurança da informação, foram avaliados os sistemas existentes seguindo a Norma ABNT NBR ISO/IEC 27001. Durante a avaliação, houve a necessidade de prover um sistema de gerenciamento de senhas interativo e com qualidade. Para criar o seu sistema, o departamento de segurança deve fazer uso do objetivo de controle:a) requisitos do negócio para controle de acesso;

b) controle de acesso ao sistema e à aplicação;

c) responsabilidade pelos ativos;

d) segurança em recursos humanos;

e) gerenciamento de acesso do usuário.

Gabaritos

1. C

11225354498 - Maria Vitória Gonçalves Vieira

2. B
3. D
4. E
5. B

11225354498 - Maria Vitória Gonçalves Vieira

ESSA LEI TODO MUNDO CONHECE:
PIRATARIA É CRIME.

Mas é sempre bom revisar o porquê e como você pode ser prejudicado com essa prática.

1. 

Professor investe seu tempo para elaborar os cursos e o site os coloca à venda.

2. 

Pirata divulga ilicitamente (grupos de rateio), utilizando-se do anonimato, nomes falsos ou laranjas (geralmente o pirata se anuncia como formador de "grupos solidários" de rateio que não visam lucro).

3. 

Pirata cria alunos fake praticando falsidade ideológica, comprando cursos do site em nome de pessoas aleatórias (usando nome, CPF, endereço e telefone de terceiros sem autorização).

4. 

Pirata compra, muitas vezes, clonando cartões de crédito (por vezes o sistema anti-fraude não consegue identificar o golpe a tempo).

5. 

Pirata fere os Termos de Uso, adultera as aulas e retira a identificação dos arquivos PDF (justamente porque a atividade é ilegal e ele não quer que seus fakes sejam identificados).

6. 

Pirata revende as aulas protegidas por direitos autorais, praticando concorrência desleal e em flagrante desrespeito à Lei de Direitos Autorais (Lei 9.610/98).

7. 

Concurseiro(a) desinformado participa de rateio, achando que nada disso está acontecendo e esperando se tornar servidor público para exigir o cumprimento das leis.

8. 

O professor que elaborou o curso não ganha nada, o site não recebe nada, e a pessoa que praticou todos os ilícitos anteriores (pirata) fica com o lucro.



Deixando de lado esse mar de sujeira, aproveitamos para agradecer a todos que adquirem os cursos honestamente e permitem que o site continue existindo.